

Security+ 3.4 · Resiliency

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.4 — Resiliency (9:42)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Sobreviver a falha: RAID 1 (mirror), RAID 5 (paridade), RAID 6 (dupla); clustering (failover); load balancing; site: hot (replica ativa), cold (sala vazia); multi-cloud/region sobrevive vendor falha.



Highlights que a prova cobra

- RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade
- Hot site = duplicado ativo; cold = só infra física



Dicas de prova & Cenários Típicos

- 'maintains uptime through component failure'=redundancy/failover

Cenário clássico de exame: 'datacenter falhou inteiro e serviço continuou'=multi-region/resiliência.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.4 — Resiliency)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Qual recurso do S3 garante durabilidade de 99.99999999% (11 noves)?

- A)** Criptografia at-rest
- B)** Versionamento e replicação cross-AZ
- C)** Lifecycle policies
- D)** Transfer Acceleration

2. Guardar backup em local geograficamente separado pra sobreviver a desastre físico é:

- A) Redundância / offsite**
- B) Menor privilégio**
- C) Não-repúdio**
- D) Ofuscação**

3. O que é escalabilidade vertical (scale up)?

- A) Adicionar mais instâncias**
- B) Aumentar recursos (CPU/RAM) da instância existente**
- C) Distribuir carga entre regiões**
- D) Implementar auto scaling**

4. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade...**

5. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Hot site = duplicado ativo; cold = só infra física'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Hot site = duplicado ativo; cold = só infra física...**

6. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'maintains uptime through component failure'=redundancy/failover'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'maintains uptime through component failure'=redundancy/failover...

7. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'datacenter falhou inteiro e serviço continuou'=multi-region/resiliência.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'datacenter falhou inteiro e serviço continuou'=multi-region/resiliência....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Hot site = duplicado ativo; cold = só infra física'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Hot site = duplicado ativo; cold = só infra física...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Resiliency): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: '"maintains uptime through component failure'=redundancy/failover'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'maintains uptime through component failure'=redundancy/failover...



GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Versionamento e replicação cross-AZ.

✓ **Por que está certa:** A alternativa correta é 'Versionamento e replicação cross-AZ'. O Amazon S3 oferece durabilidade de 99,999999999% (11 noves) porque armazena cada objeto de forma redundante em múltiplas instalações dentro de uma região, distribuídas em pelo menos três Zonas de Disponibilidade (AZs). O versionamento protege contra exclusões acidentais e sobrescritas, mantendo versões anteriores dos objetos, enquanto a replicação cross-AZ (e também a replicação cross-region, opcional) garante que os dados existam em locais fisicamente separados. Essa combinação de redundância geográfica e histórico de versões é o que sustenta a durabilidade de 11 noves. A CompTIA aborda durabilidade como a probabilidade de os dados não serem perdidos, e no S3 isso é alcançado pela replicação automática entre AZs e pelo versionamento.

✗ **Por que as outras estão erradas:**

- *Criptografia at-rest:* Criptografia at-rest protege os dados contra acesso não autorizado quando armazenados, usando chaves gerenciadas pelo S3 (SSE-S3), KMS (SSE-KMS) ou pelo cliente (SSE-C). Ela é uma medida de confidencialidade, não de durabilidade. Não impede perda de dados por falha de hardware, exclusão acidental ou corrupção; portanto, não é o recurso que garante os 11 noves de durabilidade.
- *Lifecycle policies:* Lifecycle policies são regras que automatizam a transição de objetos entre classes de armazenamento (ex.: Standard para Glacier) ou a expiração/exclusão após um período. Elas ajudam a otimizar custos e gerenciar o ciclo de vida dos dados, mas não aumentam a durabilidade intrínseca do S3. Na verdade, políticas mal configuradas podem levar à exclusão de dados, reduzindo a disponibilidade. Não é o mecanismo que assegura os 11 noves.
- *Transfer Acceleration:* Transfer Acceleration é um recurso que usa os edge locations da CloudFront para acelerar uploads e downloads de longa distância, melhorando a performance de transferência. Não tem relação com durabilidade ou redundância de armazenamento; é uma otimização de rede. Portanto, não contribui para a garantia de 99,999999999% de durabilidade.

2) A — Redundância / offsite.

✓ **Por que está certa:** Redundância / offsite refere-se à prática de manter cópias de backup em um local geograficamente separado da instalação principal, de modo que um desastre físico (incêndio, inundação, terremoto) não destrua simultaneamente os dados originais e as cópias. Isso é parte do objetivo SY0-701 3.4 (resiliência e recuperação) e 4.1 (controles de backup). A questão descreve exatamente guardar backup em local geograficamente separado para sobreviver a desastre físico, que é a definição de redundância offsite.

✗ **Por que as outras estão erradas:**

- *Menor privilégio:* Princípio do menor privilégio (least privilege) determina que usuários, processos e sistemas recebam apenas os acessos necessários para realizar suas funções, e nada além. É um controle de acesso que reduz a superfície de ataque e o impacto de comprometimentos. Não tem relação com armazenamento de backup em local separado; é um princípio de autorização, não de continuidade de negócios ou recuperação de desastres. A questão pede uma estratégia de backup geograficamente separado, não uma política de privilégios.
- *Não-repúdio:* Não-repúdio (non-repudiation) é a garantia de que uma parte não possa negar a autoria de uma ação ou transação, geralmente implementada por assinaturas digitais e logs auditáveis. É um princípio de segurança relacionado à integridade e autenticidade de transações, não ao armazenamento de backups. A questão trata de sobrevivência a desastre físico por meio de backup offsite, o que não é abordado pelo não-repúdio.
- *Ofuscação:* Ofuscação é a técnica de tornar código ou dados difíceis de entender, com o objetivo

de dificultar a análise por atacantes ou proteger propriedade intelectual. Não fornece redundância nem proteção contra desastres físicos. A questão pede uma estratégia de backup em local separado para sobreviver a desastre, o que não é função da ofuscação.

3) B — Aumentar recursos (CPU/RAM) da instância existente.

✓ **Por que está certa:** A alternativa correta é 'Aumentar recursos (CPU/RAM) da instância existente'. Escalabilidade vertical, também chamada de scale up, consiste em aumentar a capacidade de um único servidor ou instância adicionando mais recursos de hardware, como CPU, memória RAM, armazenamento ou largura de banda. O objetivo é tornar a máquina existente mais potente para lidar com maior carga. É um processo geralmente limitado pelo máximo de recursos que uma única máquina pode suportar e pode exigir reinicialização. A CompTIA define escalabilidade vertical como o aumento da capacidade de um recurso existente, em oposição à horizontal, que adiciona mais nós.

✗ **Por que as outras estão erradas:**

- *Adicionar mais instâncias:* Adicionar mais instâncias é escalabilidade horizontal (scale out), que aumenta a capacidade distribuindo a carga entre múltiplos servidores ou nós. É o oposto da vertical, que foca em fortalecer uma única instância. Portanto, não descreve scale up.
- *Distribuir carga entre regiões:* Distribuir carga entre regiões é uma estratégia de escalabilidade geográfica e de alta disponibilidade, geralmente associada a balanceamento de carga global e replicação entre regiões. Não é o conceito de escalabilidade vertical, que atua em um único servidor aumentando seus recursos.
- *Implementar auto scaling:* Auto scaling é um mecanismo que ajusta automaticamente a quantidade de instâncias (escalabilidade horizontal) com base em métricas como CPU ou tráfego. Embora possa incluir políticas de scale up e scale down, o termo 'auto scaling' normalmente se refere à elasticidade horizontal, não ao aumento de recursos de uma instância existente. Portanto, não define escalabilidade vertical.

4) D — Implementar a solução correspondente: RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: Hot site = duplicado ativo; cold = só infra física....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): Hot site = duplicado ativo; cold = só infra física.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'maintains uptime through component failure'=redundancy/failover....

✓ **Por que está certa**: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): 'maintains uptime through component failure'=redundancy/failover.

✗ **Por que as outras estão erradas**:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'datacenter falhou inteiro e serviço continuou'=multi-region/resiliência.....

✓ **Por que está certa**: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): 'datacenter falhou inteiro e serviço continuou'=multi-region/resiliência..

✗ **Por que as outras estão erradas**:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade....

✓ **Por que está certa**: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): RAID 1 = espelho; RAID 5 = paridade; RAID 6 = dupla-paridade.

✗ **Por que as outras estão erradas**:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Hot site = duplicado ativo; cold = só infra física....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): Hot site = duplicado ativo; cold = só infra física.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'maintains uptime through component failure'=redundancy/failover....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Resiliency): 'maintains uptime through component failure'=redundancy/failover.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.